CRISC Domain B – 100 Real-Life Questions

IT Risk Assessment – Practical Scenarios for Daily Challenges

CRISC Mastery Series

October 23, 2026

Instructions

How to Use This Deck

Think like a risk practitioner in a real organization.
Focus on business context, ownership, and practical decision-making.
The answer and a key takeaway are on the slide following each question.

Outline

1. Risk Identification
2. Risk Analysis
3. Risk Evaluation and Response
4. Business Impact Analysis (BIA)
5. Governance and Risk Culture
6. Monitoring and Reporting
7. Conclusion

Q1: Startup Cloud Migration

Question

A fast-growing startup is moving all its systems to the cloud. The new CISO wants to understand the risks. What should be the **FIRST** step?

- (A) Perform a penetration test on the cloud provider
- (B) Review the provider's SOC 2 report
- (C) Meet with business leaders to understand their goals and priorities
- (D) Negotiate a better SLA to cover security incidents

Q1: Explanation

Correct Answer: C

- Risk is about the impact on business objectives.
- You must know what the business is trying to achieve to identify what could go wrong.
- Technical checks and contract reviews come after understanding the business context.

Key Takeaway

You can't assess risk without first knowing the business objectives.

Q2: The Shadow IT Discovery

Question

A security analyst discovers a marketing team is using an unsanctioned SaaS tool to store customer analytics. What is the **BEST** course of action?

- (A) Immediately block access to the tool
- (B) Report the marketing team to their manager
- (C) Ignore it, as the data is only for analytics
- (D) Talk to the marketing team to understand how they use the tool and what data is involved

Q2: Explanation

Correct Answer: D

- The first step is to understand the situation.
- What data is being stored? What is the business value?
- Blocking might disrupt important work and damage security's relationship with the business.
- A risk assessment should follow, but discovery and understanding come first.

Key Takeaway

Understand the "why" before taking disruptive action.

Q3: New Regulation Impact

Question

A new data privacy regulation is passed that will take effect in 12 months. What should the risk practitioner do **NOW**?

- (A) Wait for the effective date to see if it is enforced
- (B) Purchase new privacy software
- (C) Conduct a gap assessment to see how current practices align with the new law
- (D) Update the company website's privacy policy

Q3: Explanation

Correct Answer: C

- The law will create new obligations.
- A gap assessment identifies where the organization is currently non-compliant.
- This allows for planning, budgeting, and remediation before the deadline.
- Actions like buying software or updating policies should follow the assessment.

Key Takeaway

Understand the gap before you try to close it.

Q4: Board Risk Report

Question

You are preparing a risk report for the board of directors. Which of the following is the **MOST** important to include?

- (A) A list of all 500 vulnerabilities found in the last scan
- (B) A technical summary of the firewall rules
- (C) A summary of the top risks, their potential business impact, and status versus risk appetite
- (D) The number of phishing emails blocked by the email gateway

Q4: Explanation

Correct Answer: C

- The board is responsible for governance and strategic oversight.
- They need information that is relevant to business objectives.
- Technical details and raw counts are not useful for high-level decision-making.

Key Takeaway

Speak the board's language: business impact and risk posture.

Q5: After a Major Incident

Question

A ransomware attack was just contained. The business is back online. What is the **MOST** important risk-related activity to do next?

- (A) Buy a new firewall
- (B) Have a lessons-learned meeting to update the risk register and scenarios
- (C) Fire the employee whose credentials were stolen
- (D) Increase the security budget

Q5: Explanation

Correct Answer: B

- The incident was a risk that materialized.
- Root cause analysis reveals why controls failed and how the risk assessment missed or underestimated the scenario.
- The risk register, scenarios, and controls should be updated to reflect this new information.

Key Takeaway

Treat a major incident as a learning opportunity to improve the risk process.

Q6: New E-commerce Platform

Question

The business wants to launch a new e-commerce platform in three months. As the risk practitioner, what is your **FIRST** priority?

- (A) Ensure all payment card data is encrypted
- (B) Perform a threat modeling exercise for the new platform
- (C) Include the risk practitioner in the project from the beginning to identify risks as they arise
- (D) Request a budget for a 24/7 security operations center

Q6: Explanation

Correct Answer: C

- Risk identification is a continuous process.
- Being involved early allows you to influence the design and identify risks before they become embedded in the solution.
- Specific controls and activities should be based on identified risks.

Key Takeaway

Embed risk management into the project, don't bolt it on at the end.

Q7: Cloud Provider Assurance

Question

Your critical payroll system is moving to a new SaaS provider. Which of the following sources of assurance is **MOST** reliable?

- A. The provider's marketing materials claiming they are "secure"
- B. A recent, independent, third-party audit report (e.g., SOC 2 Type II)
- C. The provider's answers to a security questionnaire
- D. A verbal assurance from the provider's sales representative

Q7: Explanation

Correct Answer: B

- An independent audit provides objective, evidence-based validation of controls over a period.
- Marketing materials and verbal assurances are not verifiable.
- Questionnaires are helpful but self-reported by the vendor.

Key Takeaway

Seek objective, independent evidence for critical vendors.

Q8: The Delphi Technique

Question

You need to identify the potential risks of a new, innovative technology that has no historical data. You want to avoid one person's strong opinion dominating the discussion. Which technique is **BEST**?

- **A** Brainstorming with all stakeholders
- **B** The Delphi technique, using anonymous input from experts
- **C** A checklist-based review from a past project
- **D** A structured walkthrough of the system design

Q8: Explanation

Correct Answer: B

- The Delphi technique uses anonymous, structured questionnaires with experts.
- This prevents a single strong personality from unduly influencing the group.
- It is excellent for new or complex situations where historical data is lacking.

Key Takeaway

For unbiased expert consensus, use the Delphi technique.

Q9: Vendor Risk Assessment

Question

Your company is onboarding a new vendor for a low-risk, non-critical service. What is the **MOST** appropriate level of risk assessment?

- (A) No assessment is needed since it's a low-risk service
- (B) A full, in-person, week-long audit of the vendor's facilities
- (C) A proportionate assessment, such as a security questionnaire, based on the risk
- (D) Rely on the vendor's reputation in the market

Q9: Explanation

Correct Answer: C

- Risk assessment should be proportionate to the risk.
- A low-risk vendor does not require a resource-intensive audit.
- A questionnaire is a reasonable, cost-effective way to gain some assurance.
- No assessment or relying only on reputation leaves the organization exposed.

Key Takeaway

Match the depth of your assessment to the level of risk.

Q10: Merger and Acquisition

Question

Your company is acquiring another firm. You need to understand the cybersecurity risks of the acquisition. What should you do **FIRST**?

- (A) Immediately integrate the acquired company's network into yours
- (B) Conduct a risk assessment of the acquired company's environment
- (C) Terminate all IT staff at the acquired company
- (D) Migrate all their data to your data centers

Q10: Explanation

Correct Answer: B

- Connecting networks or migrating data before an assessment can introduce unknown risks.
- An assessment will identify vulnerabilities, control gaps, and areas of non-compliance.
- This allows for a planned, risk-based integration.

Key Takeaway

Assess the risk before you connect the networks.

Q11: Phishing Simulation Results

Question

A phishing simulation shows a 30% click rate. What is the **BEST** way to interpret and act on this result?

- **A** It's a technical problem; the email filter needs to be improved
- **B** It confirms that employees are the weakest link and should be disciplined
- **C** It indicates a need for targeted security awareness training
- **D** The simulation was too hard; the next one should be easier

Q11: Explanation

Correct Answer: C

- A high click rate is a human risk, not just a technical one.
- The most effective response is to improve the knowledge and skills of the employees through training.
- While filters are important, they will never be 100% effective.

Key Takeaway

Address human risk with education, not just technology.

Q12: Third-Party Data Breach

Question

You learn that a third-party vendor holding your customer data has suffered a breach. What is your **FIRST** priority?

- (A) Terminate the contract with the vendor
- (B) Determine the scope of the breach and what data was affected
- (C) Issue a press release to get ahead of the story
- (D) Sue the vendor for damages

Q12: Explanation

Correct Answer: B

- You cannot respond effectively without knowing what happened.
- Understanding the scope and impact is essential for determining your notification obligations (legal, regulatory, customer) and the appropriate response.
- Legal and contractual actions follow the initial investigation.

Key Takeaway

Understand the incident before you react to it.

Q13: Board Appetite Statement

Question

The board has a very low risk appetite for data breaches. Which of the following activities is **MOST** aligned with this statement?

- (A) Investing in the latest marketing automation tool
- (B) Prioritizing the implementation of data loss prevention (DLP) controls
- (C) Upgrading the office coffee machines
- (D) Reducing the security budget to increase profitability

Q13: Explanation

Correct Answer: B

- The risk appetite is the amount of risk the organization is willing to accept.
- A low appetite for data breaches means the organization should invest in controls that prevent them.
- DLP directly addresses the risk of data loss.
- Other activities do not directly relate to the stated appetite.

Key Takeaway

Investments should be aligned with the board's risk appetite.

Q14: Risk Register Update

Question

A project manager tells you they "don't have time" to update the risk register. What is the **BEST** way to respond?

- (A) Escalate the issue to their manager
- (B) Update the register for them
- (C) Explain how the register helps them track issues and protects them if a risk materializes
- (D) Agree that it is a low priority

Q14: Explanation

Correct Answer: C

- The register is a tool for the project manager, not just a compliance exercise.
- It helps them manage their project and provides a record of due diligence.
- Framing it as a benefit, rather than a burden, is more likely to gain buy-in.

Key Takeaway

Help project managers see the value of risk management for themselves.

Q15: Emerging Technology Adoption

Question

The business wants to adopt a new generative AI tool. What is the **MOST** important risk consideration?

- (A) The cost of the tool
- (B) The potential for the AI to generate incorrect or biased information
- (C) The vendor's stock price
- (D) The ease of use for employees

Q15: Explanation

Correct Answer: B

- Generative AI introduces new risks, such as hallucination, bias, and data leakage.
- Understanding these potential negative outcomes (incorrect decisions, reputational damage) is a primary risk concern.
- While cost is a factor, it is not the primary risk driver.

Key Takeaway

For emerging tech, focus on the new and unique risks it introduces.

Q16: SLE Calculation

Question

An asset is valued at $200,000. A risk event would destroy 40% of its value. What is the Single Loss Expectancy (SLE)?

- A $80,000
- B $200,000
- C $120,000
- D $40,000

Q16: Explanation

Correct Answer: A

- SLE = Asset Value (AV) $\times$ Exposure Factor (EF).
- SLE = \$200,000 $\times$ 0.40 = \$80,000.
- This is the expected loss from a single occurrence of the risk event.

Key Takeaway

SLE is the loss from one event: AV $\times$ EF.

Q17: ALE Calculation

Question

The SLE for a specific risk is $50,000. The organization expects this event to occur once every two years. What is the Annualized Loss Expectancy (ALE)?

- A $100,000
- B $50,000
- C $25,000
- D $200,000

Q17: Explanation

Correct Answer: C

- The Annualized Rate of Occurrence (ARO) is 0.5 (once every two years).
- ALE = SLE $\times$ ARO.
- ALE = \$50,000 $\times$ 0.5 = \$25,000.

Key Takeaway

ALE is the expected annual loss: SLE $\times$ ARO.

Q18: Control Cost Justification

Question

A control would cost $30,000 per year. It reduces the ALE of a risk from $100,000 to $20,000. What is the net benefit of the control?

- A $80,000
- B $30,000
- C $50,000
- D -$10,000

Q18: Explanation

Correct Answer: C

- The control reduces the expected loss by $80,000 ($100,000 - $20,000).
- The net benefit is the loss reduction minus the control cost.
- Net Benefit = $80,000 - $30,000 = $50,000.

Key Takeaway

Justify controls by their net benefit, not just their cost.

Q19: Qualitative vs Quantitative

Question

A manager argues for a quantitative risk analysis for a new project. What is the **PRIMARY** benefit they are likely seeking?

- A. It is faster and cheaper to perform
- B. It provides a monetary value for the risk, aiding in financial decisions
- C. It is based on the subjective opinions of experts
- D. It requires less data to be effective

Q19: Explanation

Correct Answer: B

- Quantitative analysis provides a monetary (e.g., dollar) value for risk.
- This is extremely useful for comparing risks, prioritizing investments, and communicating with financial stakeholders (like the CFO or board).
- Qualitative analysis is faster and cheaper but provides subjective ratings (High/Medium/Low).

Key Takeaway

Choose quantitative analysis when you need to speak in dollars.

Q20: Risk Score Aggregation

Question

You have five independent risks, each with a 'Medium' rating. The CRO asks for an aggregate view. What is the **MOST** accurate statement?

- A. The aggregate risk is 'Medium'
- B. The aggregate risk is five times the individual risk
- C. The aggregate risk is likely higher than any single 'Medium' risk and should be assessed as a portfolio
- D. The aggregate risk is zero because they are independent

Q20: Explanation

Correct Answer: C

- Risk is not additive in a simple way.
- Five independent medium risks can create a portfolio of exposure that is higher than any individual risk.
- Aggregating risks by business unit, asset, or risk type is a critical part of enterprise risk management.

Key Takeaway

Look at the portfolio, not just the individual items.

Q21: Inherent vs Residual Risk

Question

A firewall is installed to protect a web server. The risk of an external attack before the firewall was installed is an example of what type of risk?

- A. Residual risk
- B. Current risk
- C. Inherent risk
- D. Transferred risk

Q21: Explanation

Correct Answer: C

- Inherent risk is the level of risk present before any controls are applied.
- The firewall is the control.
- The risk remaining after the firewall is implemented is the residual risk.

Key Takeaway

Inherent is before controls; residual is after.

Q22: Risk Appetite and Tolerance

Question

A risk has been assessed. Its level is currently above the stated risk appetite but below the risk tolerance. What is the **MOST** appropriate action?

- (A) Do nothing, as it is below tolerance
- (B) Implement immediate corrective controls to bring it within appetite
- (C) Monitor the risk closely and consider action if it trends toward tolerance
- (D) Ignore the appetite statement and use only tolerance

Q22: Explanation

Correct Answer: C

- Appetite is the desired level of risk.
- Tolerance is the acceptable deviation from appetite.
- A risk between appetite and tolerance is not in an ideal state but is still within acceptable bounds. It requires monitoring, not immediate panic, but action may be needed if it worsens.

Key Takeaway

Appetite is the goal, tolerance is the buffer. Manage the space between.

Q23: New Threat Intelligence

Question

You receive threat intelligence about a new exploit targeting a software your company uses. What is the **FIRST** step in analyzing this information?

- (A) Immediately shut down the affected systems
- (B) Forward the intelligence to the IT team to patch
- (C) Verify if your organization is actually vulnerable to this specific exploit
- (D) Wait for a vendor patch to be released

Q23: Explanation

Correct Answer: C

- Threat intelligence is not a confirmed risk until you verify your exposure.
- Do you use the specific version of the software? Do you have compensating controls?
- This analysis determines if and how you should respond.

Key Takeaway

Threat intel is a data point; validate its applicability to your environment.

Q24: Scenario Development

Question

When developing a risk scenario for a new database, what is the **MOST** important element to include?

- (A) The version of the database software
- (B) The name of the database administrator
- (C) The potential threat, the vulnerability it could exploit, and the business impact
- (D) The server's IP address

Q24: Explanation

Correct Answer: C

- A risk scenario must link a cause (threat and vulnerability) to a consequence (business impact).
- The technical details (version, IP) are inputs, but the scenario is a narrative of what could happen and why it matters.
- Without a business impact, it's not a fully formed risk.

Key Takeaway

A good risk scenario tells a story: cause, event, and consequence.

Q25: Expert Judgment Bias

Question

A team of senior IT engineers assesses a risk as "low" because the technology is familiar to them. What cognitive bias might be at play?

- A. Confirmation bias
- B. Anchoring bias
- C. Availability bias
- D. Overconfidence bias

Q25: Explanation

Correct Answer: D

- Overconfidence bias occurs when experts overestimate their own abilities and the safety of their domain.
- Familiarity with the technology can lead to an underestimation of the risks associated with it.
- Seeking diverse perspectives can help counter this.

Key Takeaway

Experts can be overconfident; challenge their assumptions.

Q26: Key Risk Indicator (KRI)

Question

Which of the following is the **BEST** example of a leading Key Risk Indicator (KRI) for a system availability risk?

- **A** The total hours of unplanned downtime last month
- **B** The number of production incidents last quarter
- **C** The trend of increasing server CPU utilization
- **D** The cost of the last outage

Q26: Explanation

Correct Answer: C

- A leading indicator is predictive; it changes before the risk event occurs.
- Increasing CPU utilization suggests the system is approaching a threshold that could lead to an outage.
- The other options are lagging indicators; they report on events that have already happened.

Key Takeaway

KRIs should look forward, not backward.

Q27: Risk Data Quality

Question

You are using historical incident data from three years ago to estimate the likelihood of a risk. The business has since transformed its technology stack. What is the **PRIMARY** concern with this data?

- A. The data is too old.
- B. The data is not relevant to the current environment.
- C. There is not enough data.
- D. The data is not accurate.

Q27: Explanation

Correct Answer: B

- The key issue is the relevance or representativeness of the data.
- A transformed technology stack means past data may not reflect current threats, vulnerabilities, or controls.
- The analysis could be significantly over- or under-stated as a result.

Key Takeaway

Old data isn't just old; it may be irrelevant. Check its context.

Q28: Control Effectiveness

Question

After implementing a new control, you want to determine its effectiveness. What is the **MOST** direct way to do this?

- (A) Review the design documents for the control
- (B) Interview the control owner
- (C) Test the control to see if it is operating as intended
- (D) Read the vendor's marketing brochure for the control

Q28: Explanation

Correct Answer: C

- A control's design can look good on paper, but it's only effective if it operates correctly in the real world.
- Testing provides direct evidence of the control's operating effectiveness.
- The other options are indirect or provide evidence only about the design.

Key Takeaway

The only way to know if a control works is to test it.

Q29: Risk Assessment Scope

Question

An organization is performing its annual risk assessment. What is the **BEST** way to define the scope?

- A. All IT systems managed by the IT department
- B. The systems that were tested last year
- C. The critical business processes and the IT systems that support them
- D. All systems mentioned in the latest audit report

Q29: Explanation

Correct Answer: C

- Risk is about impact on the business.
- The scope should be driven by the business processes that are most critical to achieving objectives.
- This ensures that IT risk management is aligned with enterprise risk management.

Key Takeaway

Scope your risk assessment around business value, not just IT assets.

Q30: Residual Risk Acceptance

Question

After implementing controls, the residual risk is still above the organization's risk appetite. Who is the **BEST** person to formally accept this risk?

- (A) The control owner
- (B) The IT manager
- (C) The business owner who benefits from the process
- (D) The risk practitioner

Q30: Explanation

Correct Answer: C

- Risk acceptance is a business decision.
- The person who owns the business process and bears the consequences of the risk should be the one to accept it.
- They have the authority and accountability to do so.

Key Takeaway

The person who bears the risk should accept the risk.

Q31: Risk Response Options

Question

A risk has been identified. The cost to mitigate it exceeds the potential loss. What is the **MOST** likely appropriate risk response?

- (A) Avoid the risk by ceasing the activity
- (B) Transfer the risk to an insurance company
- (C) Accept the risk and monitor it
- (D) Implement the expensive mitigation anyway

Q31: Explanation

Correct Answer: C

- When the cost of a control is greater than the benefit it provides, it is not a sound investment.
- Accepting the risk is a valid response when the risk is within tolerance and the cost to treat it is disproportionate.
- The acceptance must be documented and approved.

Key Takeaway

Don't spend more to fix a risk than the risk is worth.

Q32: Insurance as a Control

Question

A company buys cyber insurance. This is an example of which risk response strategy?

- (A) Mitigation
- (B) Avoidance
- (C) Transfer
- (D) Acceptance

Q32: Explanation

Correct Answer: C

- Risk transfer involves shifting the financial consequence of a risk to a third party, like an insurer.
- It does not eliminate the risk itself, but it transfers the financial impact.
- The organization is still responsible for managing the incident and its reputational damage.

Key Takeaway

Insurance transfers financial impact, not accountability.

Q33: Risk Mitigation Example

Question

Implementing a multi-factor authentication (MFA) system is an example of which risk response?

- A Risk acceptance
- B Risk transfer
- C Risk avoidance
- D Risk mitigation

Q33: Explanation

Correct Answer: D

- Risk mitigation involves taking action to reduce the likelihood or impact of a risk.
- MFA reduces the likelihood of unauthorized access by making credential theft less effective.
- It is a direct action to lower the risk.

Key Takeaway

Mitigation is about reducing the risk, not just shifting it.

Q34: Risk Avoidance Example

Question

A company decides not to enter a new market because of the high regulatory and legal risks. This is an example of what?

- (A) Risk acceptance
- (B) Risk mitigation
- (C) Risk avoidance
- (D) Risk transfer

Q34: Explanation

Correct Answer: C

- Risk avoidance is the decision to not perform an activity that carries risk.
- By not entering the market, the company completely avoids the associated risks.
- This is different from mitigating a risk to make an activity safer.

Key Takeaway

Avoidance means you stop doing the risky thing entirely.

Q35: Compensating Controls

Question

A legacy system cannot be patched and has a known vulnerability. To manage the risk, the team places the system behind a firewall and monitors its traffic closely. These new measures are examples of what?

- A. Preventive controls
- B. Detective controls
- C. Compensating controls
- D. Corrective controls

Q35: Explanation

Correct Answer: C

- Compensating controls are alternative safeguards implemented when the primary control (patching) is not feasible.
- They are designed to reduce the risk to an acceptable level through other means.
- A firewall and monitoring act as a substitute for the missing patch.

Key Takeaway

When you can't fix the root cause, compensate with other controls.

Q36: Risk Owner Role

Question

What is the primary responsibility of a risk owner?

- A To perform the technical testing of controls
- B To implement the risk response plan and be accountable for the risk
- C To write the risk management policy
- D To conduct audits of the risk management process

Q36: Explanation

Correct Answer: B

- The risk owner is accountable for managing a specific risk.
- They are responsible for ensuring that the chosen risk response is implemented and that the risk remains within acceptable limits.
- This includes providing resources and making decisions.

Key Takeaway

The risk owner is the accountable person for a specific risk.

Q37: Control Owner Role

Question

After a risk response is approved, who is responsible for the day-to-day operation of the implemented control?

- A. The risk owner
- B. The control owner
- C. The internal auditor
- D. The CISO

Q37: Explanation

Correct Answer: B

- The risk owner decides *what* to do, but the control owner is responsible for the *implementation and operation* of the specific control.
- The control owner is often a technical or operational person who manages the control on an ongoing basis.

Key Takeaway

The risk owner owns the risk; the control owner owns the control.

Q38: Responding to an Audit Finding

Question

An internal audit finds that a key control is not operating effectively. What is the **MOST** appropriate action for the risk practitioner?

- A. Ignore the finding as it was an internal audit
- B. Argue that the control is too expensive to fix
- C. Update the risk register and re-assess the risk with the risk owner
- D. Wait for the external audit to see if they find the same issue

Q38: Explanation

Correct Answer: C

- An audit finding provides new evidence about a control's weakness.
- This means the risk it was designed to mitigate is now higher than previously thought.
- The risk register, risk assessment, and response plan must be updated to reflect this new reality.

Key Takeaway

An audit finding is a new piece of risk information. Act on it.

Q39: Risk Monitoring

Question

What is the primary purpose of continuous risk monitoring?

- A To satisfy regulatory requirements
- B To detect changes in the risk environment and risk profile
- C To justify the budget for security tools
- D To generate data for reports

Q39: Explanation

Correct Answer: B

- The risk environment is constantly changing (new threats, business changes, control drift).
- Monitoring provides timely awareness of these changes so that the organization can adapt its risk management activities proactively.
- Compliance and reporting are secondary benefits.

Key Takeaway

Monitor risk to know when the picture changes, not just for reports.

Q40: Risk Reporting to Business

Question

When communicating a risk to a business manager, what is the **MOST** effective way to frame it?

- (A) Describe the vulnerability in technical terms, including the CVE number
- (B) Provide a list of the specific firewall rules that were bypassed
- (C) Explain the potential impact on their business goals, such as revenue, customer trust, or operational efficiency
- (D) Give them a copy of the technical risk assessment report

Q40: Explanation

Correct Answer: C

- Business managers care about business objectives.
- Framing the risk in terms of its potential impact on their area (e.g., "this could disrupt our sales process," "this could lead to fines") is the most effective way to gain their attention and support for a response.

Key Takeaway

Translate technical risk into business impact.

Q41: New Business Initiative

Question

The business wants to launch a new service that uses a new technology. The risk assessment shows the inherent risk is high. What should the risk practitioner do?

- A. Block the initiative because the risk is too high
- B. Approve the initiative without further discussion
- C. Work with the business to identify controls to mitigate the risk to an acceptable level
- D. Tell the business they must accept all the risk

Q41: Explanation

Correct Answer: C

- The role of risk management is to enable the business, not to be a roadblock.
- High inherent risk does not mean an activity should be stopped; it means controls are needed to reduce the risk.
- The practitioner should collaborate with the business to find a way to proceed safely.

Key Takeaway

Your job is to help the business take smart risks, not avoid all risks.

Q42: Key Performance Indicator (KPI)

Question

Which of the following is a Key Performance Indicator (KPI) for a vulnerability management program?

- **A** The number of high-severity vulnerabilities currently open
- **B** The percentage of critical vulnerabilities remediated within the defined 30-day SLA
- **C** The number of new exploits in the wild this quarter
- **D** The total number of systems in the environment

Q42: Explanation

Correct Answer: B

- KPIs measure the performance and effectiveness of a process or control.
- "Percentage remediated within SLA" directly measures how well the vulnerability management process is performing against its goal.
- The other options are better classified as risk indicators (KRIs) or simple metrics.

Key Takeaway

KPIs measure performance against a goal or SLA.

Q43: Key Control Indicator (KCI)

Question

Which of the following is a Key Control Indicator (KCI)?

- (A) The number of phishing emails that bypassed the email gateway
- (B) The percentage of servers that have the latest security patches installed
- (C) The trend of external attacks on the organization's network
- (D) The number of employees who failed the last phishing simulation

Q43: Explanation

Correct Answer: B

- A KCI measures whether a specific control is in place and operating as designed.
- The "percentage of servers with the latest security patches" directly measures the performance of the patch management control.
- The other options are more related to risk (KRIs) or performance (KPIs).

Key Takeaway

KCIs measure the control itself.

Q44: Reporting an Accepted Risk

Question

A business unit has formally accepted a risk. What should the risk practitioner do with this information?

- A. Forget about it, the risk is now their problem
- B. Escalate it to the board
- C. Document it in the risk register and continue to monitor for any changes
- D. Try to secretly implement controls anyway

Q44: Explanation

Correct Answer: C

- Accepting a risk is a formal decision.
- The decision and its rationale must be documented (in the risk register) for accountability and future reference.
- The risk practitioner should continue to monitor the risk to ensure the basis for acceptance remains valid.

Key Takeaway

Accepted risk is still tracked risk. Document and monitor it.

Q45: Risk Assessment Frequency

Question

How often should a risk assessment be performed?

- A. Only once per year
- B. Only when a major incident occurs
- C. At planned intervals and whenever there is a significant change
- D. Every time a new employee is hired

Q45: Explanation

Correct Answer: C

- Risk management is continuous, but formal risk assessments are periodic.
- They should be performed on a regular schedule (e.g., annually) to catch drift.
- They must also be triggered by significant events, such as a merger, a new technology adoption, or a major incident.

Key Takeaway

Periodic and event-driven: the two triggers for a risk assessment.

Q46: Risk Appetite Communication

Question

How can an organization ensure that its risk appetite is understood and used by all employees?

- **A** By mentioning it once in the annual code of conduct training
- **B** By translating the high-level appetite statement into specific policies, procedures, and decision-making criteria for different teams
- **C** By posting the statement on the company intranet
- **D** By having the CRO sign off on the statement

Q46: Explanation

Correct Answer: B

- A vague, high-level statement is not actionable for most employees.
- To be effective, the appetite must be operationalized—translated into concrete rules like "any risk above $X requires CFO approval" or "we will not use any software that is not on the approved list."
- This makes it part of daily work.

Key Takeaway

Make risk appetite practical, not just a philosophical statement.

Q47: Mitigation vs. Acceptance Trade-off

Question

A risk has a potential loss of $1 million. A control to mitigate it would cost $200,000 per year. The risk is considered to have a low likelihood. What is the **MOST** important factor to consider before deciding?

- A. The $200,000 cost is only 20% of the loss.
- B. The precise likelihood of the risk occurring.
- C. The risk practitioner's opinion.
- D. What competitors are doing about this risk.

Q47: Explanation

Correct Answer: B

- You have the impact ($1M) and the cost ($200k).
- The likelihood is the missing piece of the equation.
- If the risk is extremely rare (e.g., 1-in-100 years), the annualized loss expectancy might be very low, making the $200k/year control difficult to justify. The final decision hinges on a better estimate of the likelihood.

Key Takeaway

To justify a control, you need to know the likelihood, not just the impact.

Q48: Shadow AI

Question

A software developer is using a public generative AI tool to write code, copy-pasting company code into it. What is the **PRIMARY** risk?

- A. The AI might generate buggy code.
- B. The developer might become too dependent on the AI.
- C. Company intellectual property could be leaked into the public domain.
- D. The AI tool might be unavailable.

Q48: Explanation

Correct Answer: C

- Pasting proprietary source code into public tools can result in that code being retained, used for training, or otherwise exposed.
- This is a significant data leak and intellectual property risk.
- While code quality is a concern, the confidentiality risk is often the most severe.

Key Takeaway

Public AI tools are not a safe place for proprietary data.

Q49: Vendor Lock-in

Question

A company has all its data in a proprietary cloud platform, making it very difficult to move to another provider. What type of risk does this represent?

- A. Compliance risk
- B. Concentration risk
- C. Reputational risk
- D. Strategic risk

Q49: Explanation

Correct Answer: B

- Concentration risk is the risk of relying on a single partner or technology.
- Being locked in increases the impact of any failure, price increase, or policy change by that single vendor.
- It limits the organization's flexibility and negotiating power.

Key Takeaway

Being too dependent on one provider is a risk in itself.

Q50: Post-Incident KRI Update

Question

After a major outage caused by a database corruption, what is the **BEST** way to update KRIs?

- A. No update is needed, the incident is over.
- B. Add a KRI for the "number of database backups completed."
- C. Add a KRI for "database integrity check failure rate" or "backup restore test failure rate."
- D. Remove all existing KRIs related to databases.

Q50: Explanation

Correct Answer: C

- The KRIs should have provided an early warning of this incident.
- A database integrity KRI or a backup restore test KRI might have indicated a problem before the outage.
- The goal is to add leading indicators that would have helped predict or prevent the specific event that occurred.

Key Takeaway

After an incident, ask: "What indicator would have warned us?" and add it.

Q51: BIA Purpose

Question

What is the primary purpose of a Business Impact Analysis (BIA)?

- (A) To list all the vulnerabilities in the IT environment
- (B) To determine the Recovery Time Objective (RTO) and Recovery Point Objective (RPO) for critical business processes
- (C) To calculate the financial return on investment for security tools
- (D) To document the IT architecture

Q51: Explanation

Correct Answer: B

- The BIA identifies which business processes are most critical and what the impact of a disruption would be.
- The key outputs of a BIA are the recovery objectives: RTO (how quickly must we recover?) and RPO (how much data can we lose?).
- It is a business-driven process.

Key Takeaway

BIA's main job is to set RTO and RPO for what matters most.

Q52: RTO vs RPO

Question

A system can tolerate 4 hours of downtime and a maximum of 15 minutes of data loss. What are its RTO and RPO, respectively?

- A RTO = 15 minutes, RPO = 4 hours
- B RTO = 4 hours, RPO = 15 minutes
- C RTO = 4 hours, RPO = 4 hours
- D RTO = 15 minutes, RPO = 15 minutes

Q52: Explanation

Correct Answer: B

- Recovery Time Objective (RTO) is the maximum acceptable downtime. So, RTO = 4 hours.
- Recovery Point Objective (RPO) is the maximum acceptable data loss, measured in time. So, RPO = 15 minutes.
- Think RTO = Time to recover; RPO = Point in time of last good data.

Key Takeaway

RTO is about time down; RPO is about data lost.

Q53: BIA Dependency

Question

During a BIA, it is discovered that the payroll system (RTO 24h) depends on the HR database (RTO 48h). What is the **PRIMARY** issue?

A. There is no issue, they are different systems.

B. The HR database has a higher RTO than the system it supports, creating a dependency conflict.

C. The payroll system's RTO is too strict.

D. The HR database should not have an RTO.

Q53: Explanation

Correct Answer: B

- A system cannot be recovered before the systems it depends on.
- If the payroll system must be back in 24 hours, but its dependency (the HR database) can be down for 48 hours, the payroll system's RTO is impossible to meet.
- Dependency RTOs must be less than or equal to the RTOs of the systems that depend on them.

Key Takeaway

A system's RTO is constrained by the RTOs of its dependencies.

Q54: MTD Definition

Question

Which of the following best describes the Maximum Tolerable Downtime (MTD)?

- **A** The average time it takes to recover a system
- **B** The total amount of time a business process can be unavailable before the impact becomes unacceptable
- **C** The time it takes to restore data from backup
- **D** The target recovery time for the IT team

Q54: Explanation

Correct Answer: B

- MTD is a business-level concept.
- It is the absolute limit—the point beyond which the business faces severe, potentially catastrophic consequences (e.g., bankruptcy, massive regulatory fines).
- The RTO should always be less than the MTD.

Key Takeaway

MTD is the point of no return for the business.

Q55: BIA Interdependency

Question

A BIA reveals that an e-commerce website depends on three systems: a web server, a database, and a payment gateway. All have an RTO of 2 hours. How should recovery be prioritized?

- **A** Alphabetically by system name
- **B** By the cost of each system
- **C** The foundational systems (database, payment gateway) must be recovered before or with the web server for it to function
- **D** They can all be recovered simultaneously without issue

Q55: Explanation

Correct Answer: C

- The web server is useless without the database and payment gateway.
- The recovery plan must respect these dependencies.
- The foundational systems must be brought online first or at the same time to meet the 2-hour RTO for the overall service.

Key Takeaway

Recover the foundation first, then build on top of it.

Q56: RPO and Backups

Question

A system has an RPO of 1 hour. The current backup schedule is a full backup nightly at midnight. Is this adequate?

- **A** Yes, a nightly backup is a standard practice.
- **B** No, the backup frequency is too low. The organization could lose up to 24 hours of data, which far exceeds the 1-hour RPO.
- **C** Yes, as long as the backups are encrypted.
- **D** No, the backups should be weekly instead of nightly.

Q56: Explanation

Correct Answer: B

- The RPO sets the maximum acceptable data loss.
- A nightly backup means that if a failure occurs at 11:00 PM, the last backup was at midnight, so nearly 23 hours of data would be lost.
- This violates the 1-hour RPO. More frequent backups (or log shipping/continuous replication) are needed.

Key Takeaway

Your backup schedule must be aligned with your RPO.

Q57: DR Test Failure

Question

A disaster recovery test reveals that a critical system took 10 hours to restore, but its RTO is 4 hours. What should the risk practitioner do **FIRST**?

- (A) Change the RTO to 10 hours
- (B) Blame the recovery team
- (C) Document the finding and initiate a root cause analysis to improve the recovery process
- (D) Do nothing, it was just a test

Q57: Explanation

Correct Answer: C

- A failed DR test is a critical finding. It shows the recovery capability is not as expected.
- The first step is to document the gap and find out *why* it took so long.
- The RTO should only be changed if the business agrees that a longer downtime is acceptable, which is a separate decision.

Key Takeaway

A failed test is a real finding. Analyze the cause and fix the plan.

Q58: BIA and Risk Assessment

Question

How does a Business Impact Analysis (BIA) relate to a risk assessment?

- A. They are the same thing
- B. A BIA focuses on the "what" (what processes are critical), while a risk assessment focuses on the "why" (what could disrupt them)
- C. A risk assessment is a subset of a BIA
- D. A BIA is only for natural disasters, while risk assessment is for cyber threats

Q58: Explanation

Correct Answer: B

- They are complementary.
- The BIA identifies what is critical and how quickly it needs to be recovered (the "what").
- The risk assessment identifies the threats and vulnerabilities that could cause a disruption (the "why" or "how").
- You need both to build a resilient business.

Key Takeaway

BIA tells you what to protect; risk assessment tells you what to protect it from.

Q59: Recovery Strategy Selection

Question

A critical system has an RTO of 1 hour and an MTD of 4 hours. What is the **MOST** appropriate recovery strategy?

- A. A cold site with data backups
- B. A warm site with data replication
- C. A hot site with real-time synchronous replication
- D. Daily backups to tape stored offsite

Q59: Explanation

Correct Answer: C

- An RTO of 1 hour is extremely aggressive.
- Cold, warm, or tape-based strategies will likely take many hours or days to restore.
- A hot site with synchronous replication can provide near-instantaneous failover, which is necessary to meet such a tight RTO.

Key Takeaway

The tighter the RTO, the more you need to invest in a hot, active-active or active-passive recovery solution.

Q60: Data Classification in BIA

Question

When performing a BIA, why is data classification important?

- **A** It helps determine the cost of storage.
- **B** It helps prioritize which data needs the most stringent recovery objectives (RPO).
- **C** It is required for compliance.
- **D** It helps the IT team decide which data to delete.

Q60: Explanation

Correct Answer: B

- Highly sensitive or critical data (e.g., customer PII, financial records) may have a much lower RPO (less data loss allowed) than less critical data.
- Classification helps ensure that the recovery strategy for different data sets is aligned with its business value and regulatory requirements.

Key Takeaway

Data classification is a key input to setting RPOs for different systems.

Q61: Board Oversight

Question

What is the board's role in IT risk management?

- A To approve all firewall rule changes
- B To provide oversight, set risk appetite, and ensure that an effective risk management framework exists
- C To perform the annual penetration test
- D To manage the day-to-day operations of the security team

Q61: Explanation

Correct Answer: B

- The board is responsible for governance, not management.
- They set the tone at the top by defining the risk appetite and ensuring that management has the resources and framework to manage risk effectively.
- They provide oversight but do not perform operational tasks.

Key Takeaway

The board governs; management manages.

Q62: Three Lines of Defense

Question

In the Three Lines of Defense model, who is responsible for owning and managing risk on a day-to-day basis?

- A. The first line (operational management)
- B. The second line (risk and compliance functions)
- C. The third line (internal audit)
- D. The external auditor

Q62: Explanation

Correct Answer: A

- The first line of defense is the operational management (the business itself).
- They own the risk and are responsible for implementing and operating the controls.
- The second line oversees and advises; the third line provides independent assurance.

Key Takeaway

The business is the first line of defense; they own the risk.

Q63: Risk Culture

Question

Which of the following is the **MOST** effective way to build a strong risk culture?

- (A) Publishing a risk policy on the company intranet
- (B) Giving employees a bonus for never reporting any risks
- (C) Leaders consistently modeling the desired risk-aware behavior and rewarding transparency
- (D) Requiring all employees to take an annual 30-minute training session

Q63: Explanation

Correct Answer: C

- Culture is shaped by what leaders do, not just what they say.
- When leaders consistently demonstrate that risk management is a priority and that they will not punish people for raising concerns, it sends a powerful message.
- Training and policies are important, but they are less impactful than consistent leadership behavior.

Key Takeaway

Culture is caught, not just taught. Leaders set the example.

Q64: Risk Appetite Statement

Question

Which of the following is a well-defined risk appetite statement?

A. "We will not accept any risk."

B. "We have a moderate appetite for IT risk."

C. "We will not tolerate any unauthorized access to customer PII. The loss of more than 1,000 customer records is a significant event requiring board notification."

D. "We will comply with all laws and regulations."

Q64: Explanation

Correct Answer: C

- A good risk appetite statement is specific and measurable.
- It defines concrete thresholds that tell you when a risk is approaching a level that requires action or escalation.
- Vague terms like "moderate" or "no risk" are not actionable.

Key Takeaway

A good appetite statement has numbers and consequences.

Q65: Communication with Regulators

Question

A data breach affecting customer data has occurred. A regulator requests information. What is the **BEST** approach?

- (A) Provide the minimum information possible to delay the process
- (B) Be transparent and cooperative, providing accurate and timely information as required by law
- (C) Give them a copy of the marketing report instead
- (D) Only communicate through your lawyers

Q65: Explanation

Correct Answer: B

- Transparency and cooperation are crucial during a regulatory investigation.
- Delays or misinformation can lead to penalties and increased scrutiny.
- The organization has legal and regulatory obligations to communicate truthfully.

Key Takeaway

With regulators, honesty and speed are the best policy.

Q66: Policies vs Standards

Question

What is the difference between a policy and a standard?

- A. They are the same thing.
- B. A policy is a high-level statement of intent, while a standard is a mandatory, specific requirement to meet that intent.
- C. A standard is optional, while a policy is mandatory.
- D. A policy is technical, while a standard is for business people.

Q66: Explanation

Correct Answer: B

- Policies are high-level: "All customer data must be encrypted."
- Standards are specific and mandatory: "All customer data at rest must be encrypted using AES-256."
- Policies are the "what," standards are the "how."

Key Takeaway

Policies are the "why," standards are the "how much."

Q67: Exception Management

Question

A business unit requests an exception to a security policy to meet a critical deadline. What is the **BEST** practice?

- (A) Grant the exception verbally to save time
- (B) Deny the exception; policies are absolute
- (C) Follow a formal process to evaluate the risk, approve the exception, document it with an expiration date, and implement compensating controls
- (D) Grant the exception permanently so they don't have to ask again

Q67: Explanation

Correct Answer: C

- Exceptions are sometimes necessary, but they must be managed.
- A formal process ensures that the risk is understood and approved by the right person.
- The exception should be time-bound and include compensating controls to manage the added risk.

Key Takeaway

Exceptions are okay, but they must be documented, temporary, and controlled.

Q68: Risk Assessment Scope

Question

An organization is performing its annual risk assessment. What is the **BEST** way to define the scope?

- A. All IT systems managed by the IT department
- B. The systems that were tested last year
- C. The critical business processes and the IT systems that support them
- D. All systems mentioned in the latest audit report

Q68: Explanation

Correct Answer: C

- Risk is about impact on the business.
- The scope should be driven by the business processes that are most critical to achieving objectives.
- This ensures that IT risk management is aligned with enterprise risk management.

Key Takeaway

Scope your risk assessment around business value, not just IT assets.

Q69: Residual Risk Acceptance

Question

After implementing controls, the residual risk is still above the organization's risk appetite. Who is the **BEST** person to formally accept this risk?

- (A) The control owner
- (B) The IT manager
- (C) The business owner who benefits from the process
- (D) The risk practitioner

Q69: Explanation

Correct Answer: C

- Risk acceptance is a business decision.
- The person who owns the business process and bears the consequences of the risk should be the one to accept it.
- They have the authority and accountability to do so.

Key Takeaway

The person who bears the risk should accept the risk.

Q70: Third-Party Contract Clauses

Question

To manage third-party risk effectively, which of the following contract clauses is **MOST** important?

- **A** A clause allowing the vendor to change their security practices at any time
- **B** A clause requiring the vendor to pay for any data breach, regardless of cause
- **C** A right-to-audit clause and a requirement to report security incidents within a specific timeframe (e.g., 24 hours)
- **D** A clause limiting the vendor's liability to the cost of the contract

Q70: Explanation

Correct Answer: C

- A right-to-audit clause allows you to verify the vendor's security claims.
- A notification requirement ensures you are aware of an incident quickly so you can respond.
- These contractual rights are essential for ongoing oversight.
- Unlimited liability clauses are rarely enforceable, and unlimited freedom to change security practices is dangerous.

Key Takeaway

Oversight doesn't end at onboarding; the contract must enable monitoring.

Q71: Risk Culture Metric

Question

Which of the following is the **BEST** indicator of a positive risk culture?

- A. The number of risk assessments performed per year
- B. The number of security policies in place
- C. The trend of employees reporting near-misses or potential risks without fear of blame
- D. The amount of money spent on security tools

Q71: Explanation

Correct Answer: C

- A positive risk culture is one where people are empowered and encouraged to speak up about potential problems.
- An increasing trend in near-miss reporting is a strong sign of trust and psychological safety.
- The other options measure activity or spending, not culture.

Key Takeaway

Culture is about speaking up, not just ticking boxes.

Q72: Risk Reporting to Board

Question

What should a risk report to the board of directors focus on?

- A. Detailed technical logs of security events
- B. A list of every risk identified in the organization
- C. An overview of the most significant risks, their potential business impact, and the effectiveness of the response
- D. The number of vulnerabilities remediated last month

Q72: Explanation

Correct Answer: C

- The board needs a strategic view, not an operational data dump.
- They need to understand the key risks to the business and whether the organization is managing them effectively.
- Reports should be concise, focused on impact, and linked to business objectives.

Key Takeaway

Board reports should be strategic, not technical.

Q73: Risk Assessment Methodology

Question

An organization is choosing a risk assessment methodology. What is the **MOST** important consideration?

- (A) The methodology is the most popular one in the industry
- (B) The methodology is easy to use
- (C) The methodology aligns with the organization's culture, maturity, and objectives
- (D) The methodology requires the least amount of effort

Q73: Explanation

Correct Answer: C

- The "best" methodology is the one that works for the organization.
- A highly complex, quantitative methodology may fail in an organization with a less mature risk culture.
- The choice should be driven by what is practical, useful, and understood by stakeholders.

Key Takeaway

Choose a risk methodology that fits your organization, not one that is fashionable.

Q74: Risk Response in a Project

Question

A project manager is developing a plan to respond to a risk that the project will be delayed by bad weather. They decide to add a buffer to the project schedule. This is an example of what?

- A. Risk avoidance
- B. Risk transfer
- C. Risk mitigation
- D. Risk acceptance

Q74: Explanation

Correct Answer: C

- The project manager is taking action to reduce the impact of the risk (schedule delay) by adding a buffer.
- This is a form of mitigation.
- Avoidance would be to not do the project, and transfer would be to insure against the delay.

Key Takeaway

Mitigation is about taking action to lessen the impact or likelihood.

Q75: Business Continuity vs Disaster Recovery

Question

What is the difference between Business Continuity (BC) and Disaster Recovery (DR)?

- **A** They are the same thing.
- **B** DR focuses on restoring IT systems after a disaster, while BC focuses on keeping critical business functions running during and after a disaster.
- **C** BC focuses on IT, while DR focuses on business processes.
- **D** DR is proactive, while BC is reactive.

Q75: Explanation

Correct Answer: B

- DR is a subset of BC, focused specifically on technology.
- BC is a broader, business-level plan that covers people, processes, facilities, and technology.
- The goal of BC is to keep the business alive, while DR is about getting the IT systems back online.

Key Takeaway

DR gets IT back up; BC keeps the whole business running.

Q76: KRI Design

Question

What makes a good Key Risk Indicator (KRI)?

- (A) It is easy to measure, even if it's not relevant to the risk
- (B) It is predictive of a future risk event and is measurable
- (C) It reports on past events in great detail
- (D) It is based on a single data point

Q76: Explanation

Correct Answer: B

- A good KRI should be forward-looking (predictive) so it provides an early warning.
- It must also be measurable and relevant to a specific risk.
- Lagging indicators (reporting on past events) are less useful for proactive management.

Key Takeaway

KRIs are forward-looking, not backward-looking.

Q77: KRI Alert

Question

A KRI has breached its threshold. What is the **FIRST** thing the risk practitioner should do?

- (A) Immediately implement a new control
- (B) Ignore it and wait for the next cycle
- (C) Investigate the cause of the breach to understand what is happening
- (D) Immediately escalate to the board

Q77: Explanation

Correct Answer: C

- A KRI breach is a signal, not a final diagnosis.
- The first step is to investigate: Is the data accurate? What is the root cause?
- Once the cause is understood, you can determine the appropriate action (which may involve escalating or implementing a control).

Key Takeaway

When a KRI triggers, investigate before you act.

Q78: Reporting Metrics

Question

What is the primary difference between a KPI and a KRI?

A. A KPI is for the board, while a KRI is for the IT team.

B. A KPI measures performance against a goal (e.g., how well a process is working), while a KRI measures exposure to risk.

C. A KRI is always quantitative, while a KPI is qualitative.

D. There is no difference; they are interchangeable.

Q78: Explanation

Correct Answer: B

- KPIs (Key Performance Indicators) measure how well you are doing something (e.g., 99.99
- KRIs (Key Risk Indicators) measure how much risk you are exposed to (e.g., the number of unpatched critical vulnerabilities).
- They answer different questions: "How are we doing?" vs. "How much danger are we in?"

Key Takeaway

KPIs measure performance; KRIs measure risk exposure.

Q79: Risk Register Contents

Question

Which of the following is the **MOST** essential piece of information in a risk register entry?

- A The technical name of the vulnerability
- B The name of the person who identified the risk
- C The risk statement, the assigned risk owner, and the current risk rating
- D The date the risk will be fixed

Q79: Explanation

Correct Answer: C

- The risk register is a tool for managing risk.
- To be actionable, it must state the risk clearly, have an accountable owner, and a current rating to prioritize action.
- The other details are helpful but secondary.

Key Takeaway

A risk without an owner is a problem, not a managed risk.

Q80: Risk Review with Management

Question

A risk practitioner is preparing to discuss an elevated risk with a business manager. What is the **MOST** effective approach?

- (A) Present the technical details of the vulnerability
- (B) Show the manager a report with 50 other risks
- (C) Tell the manager what control they need to implement
- (D) Explain the potential business impact of the risk and discuss options for response

Q80: Explanation

Correct Answer: D

- The goal is to enable a business decision.
- Explaining the business impact (e.g., "this could disrupt our order processing") makes the risk relevant.
- Presenting options empowers the risk owner to make an informed decision.

Key Takeaway

Focus on business impact and options, not just technical problems.

Q81: Audit Findings

Question

An external audit has identified that a control is not operating effectively. What is the risk practitioner's **MOST** appropriate response?

- (A) Dispute the finding to protect the company's image
- (B) Ignore the finding because it is external
- (C) Use the finding as input to update the risk register and re-assess the risk
- (D) Implement a new control without further analysis

Q81: Explanation

Correct Answer: C

- An audit finding is a valuable piece of evidence about a control weakness.
- It means the residual risk is higher than previously thought.
- The risk assessment and register must be updated, and a new response plan should be developed with the risk owner.

Key Takeaway

An audit finding is a gift; it's a new piece of risk information. Use it.

Q82: Emerging Risks

Question

What is the **BEST** way to identify emerging risks?

- (A) Reviewing historical incident data from the last 5 years
- (B) Continuously scanning the external environment (threat intelligence, regulatory news, industry trends)
- (C) Performing an annual risk assessment
- (D) Reviewing the most recent audit report

Q82: Explanation

Correct Answer: B

- Emerging risks, by definition, have no history.
- They must be identified by looking outward and forward at the changing environment.
- This requires continuous monitoring, not just periodic reviews of internal data.

Key Takeaway

Look outward and forward to see what's coming, not just backward.

Q83: Key Control Indicator (KCI) Alert

Question

A KCI (e.g., "percentage of access reviews completed") falls to 50%. What does this suggest?

- (A) A malicious insider attack is underway
- (B) The control designed to review access rights is not being performed consistently
- (C) The risk of unauthorized access has decreased
- (D) Nothing, the KCI is not a useful metric

Q83: Explanation

Correct Answer: B

- A KCI measures the performance of a control.
- A drop to 50% means the access review control is not being done as required.
- This means the risk of unauthorized access (the risk the control was meant to mitigate) has likely increased.

Key Takeaway

A KCI measures the control; a failing KCI means a failing control.

Q84: Risk Reporting to a Project Team

Question

A project manager needs to report on risk to the project sponsor. What is the **MOST** important information to include?

- **A** The number of vulnerabilities found in the latest scan
- **B** The top risks that could prevent the project from meeting its objectives, and the planned responses
- **C** A detailed list of every risk in the risk register
- **D** The names of the team members who identified the risks

Q84: Explanation

Correct Answer: B

- The sponsor cares about the project's success.
- They need to know what the major threats to success are and what is being done about them.
- A focus on the risks that affect project objectives is the most relevant and actionable information.

Key Takeaway

Project reports should focus on risks to project objectives.

Q85: Risk and Change Management

Question

A developer wants to make a change to a production system. Why is a formal change management process important from a risk perspective?

- **A** To slow down the developer
- **B** To ensure that the change is made without any risk
- **C** To assess the risk of the change, get approval, and have a rollback plan before implementation
- **D** To satisfy the IT department's need for paperwork

Q85: Explanation

Correct Answer: C

- Changes to production systems can introduce new risks (e.g., outages, new vulnerabilities).
- The change management process is a control to manage these risks.
- It ensures that changes are tested, approved, and can be reversed if something goes wrong.

Key Takeaway

Change management is a key control to manage the risk of introducing errors into production.

Exam Mindset Summary

Remember These Core Principles

- **Start with Business Objectives:** Always understand the business goals before identifying risks.
- **Risk is Dynamic:** Risk is not a one-time assessment; it is a continuous process of identification, assessment, response, and monitoring.
- **Owners Decide:** The risk owner, who is accountable for the business process, is the one who accepts the risk.
- **Assess Before Acting:** Understand the situation and context before taking action, especially with incidents or new technologies.
- **Proportion is Key:** The level of risk assessment and the cost of controls should be commensurate with the level of risk.
- **Communicate in Business Terms:** Translate technical risk into business impact to get stakeholder buy-in.
- **Accountability Cannot be Outsourced:** You can transfer financial risk, but you cannot transfer the accountability for a business process.

Good Luck on Your CRISC Exam!

The questions in the real exam will test your ability to apply these concepts in practical, real-world scenarios.